LABORATUVAR 5 · FİRMA SÜRÜMÜ · FADA Otonom Transfer Arabası

5

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad **Muhammed Salih Atiç** | Grup | Tarih **28.10.2026**

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir.**

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi) — bu makinede: **araç sürüş PLC'sinin firmware'i**
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   - **Bileşen var mı?** FADA'nın araç SBOM'unda (PLC tedarikçisinin bileşen listesi dahil) Component X sürüş PLC'sinde geçiyor → **var**.
   - **Sürüm etkileniyor mu?** Kurulu sürüm 2.4, CVE'nin etkilenen sürüm aralığıyla karşılaştırılır → aralıkta → **etkileniyor**.
   - **Ulaşılabilir mi?** Zafiyetli servis PLC'de açık ve Z3'ten (Wi-Fi) ya da uzak servis yolundan erişilebiliyor → **ulaşılabilir**.

   Sonuç: üç şart da sağlanıyor, araç **etkileniyor**. Safety PLC'de bu bileşen yoksa emniyet katmanı doğrudan etkilenmiyor; bu da ayrıca teyit edilir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam. CVSS ciddiyeti gösterir, sahadaki riski değil. İnsan koruması ayrı ve bağımsız Safety PLC'de devam ediyor. Önce erişim yollarını kısıtlarım (5. sorudaki önlemler) ve yamayı planlarım. **İstisna:** aktif istismar kanıtı varsa veya Safety PLC'nin de etkilendiği anlaşılırsa araçları güvenli duruşa alırım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. Sırasıyla: (1) FADA'nın Sakarya'daki test alanında, aynı yazılım ve konfigürasyondaki referans araçta veya yedek PLC'li test tezgâhında; (2) müşteri sahasında tek bir pilot araçta, düşük hız/boş yükle; (3) ardından tüm filoya kademeli geçiş. Her adımda geri dönüş planı ve eski firmware yedeği hazır olur.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Değişiklik etki analiziyle anlarım: (a) yama Safety PLC'ye veya safety ile veri paylaşan fonksiyonlara (hız sinyali, koruma alanı seçimi) dokunuyor mu, (b) tedarikçinin sürüm notu ne diyor, (c) Safety PLC program checksum'u ve tarayıcı konfigürasyonu değişiyor mu. Etkiliyorsa durma mesafesi ve koruma alanı testleri gibi emniyet fonksiyonu doğrulama testleri tekrarlanır ve teknik dosya güncellenir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   - Uzak servis erişimini varsayılan kapalı tutmak, zafiyetli servisi/portu PLC'de kapatmak
   - Conduit güvenlik duvarında yalnızca gerekli trafiğe izin vermek, Wi-Fi'ı ayrı segmente almak
   - OT ağ izleme ve saldırı tespiti ile şüpheli trafiğe alarm kurmak
   - Operasyonel önlem: araç rotasında yaya bölgelerini ayırmak, gerekirse azami hızı düşürmek
   - Müşteriyi yazılı bilgilendirmek (CRA güvenlik danışma notu) ve yama hedef tarihini kayda geçirmek

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.